

Compliance Summary

*UK GDPR · Data Protection Act 2018 · ICO Children's Code · Qatar
PDPPL – at a glance.*

Last reviewed 2026-05-24

Qatar – PDPPL (Law No. 13 of 2016)

OBLIGATION	OUR POSITION
Art. 4 — explicit consent	Captured at sign-up; recorded in an append-only consent ledger
Art. 13 — data-subject rights + 30-day response	30 calendar days, per NCGAA Individuals' Rights Guideline PDPPL-02050219E; self-service in-product
Art. 16 — prior NCGAA permission for special-category data (incl. minors)	Permit application dossier drafted and shelf-ready; submission held pending Qatari legal sign-off. Substantive posture in place regardless.
Art. 17 — cross-border transfer with explicit consent	Live in the signup flow as of 20 May 2026 — Qatar-resident users see a named-destination consent panel before account creation
Art. 22 — direct marketing opt-in + opt-out	All marketing consent-gated; every marketing email carries sender ID + unsubscribe
72-hour breach notification	Standing readiness — runbook + pre-filled NCGAA template
General controller registration	Not required under PDPPL (no general registration regime)

United Kingdom – UK GDPR + DPA 2018

ITEM	OUR POSITION
ICO registration	ZC016690 — verifiable on the ICO public register
Lawful basis	Contract for service delivery; explicit consent for AI processing of essay text; legitimate interest for security telemetry (LIA on file)
Records of Processing (Art. 30)	RoPA maintained — 12 documented activities
DPIAs (Art. 35)	Three on file: children's data, AI features, analytics
Breach notification (Art. 33–34)	72 hours to ICO + affected subjects where risk warrants
International transfers	Provider SCCs / UK addendum for transfers outside the UK/EU

Children – ICO Age Appropriate Design Code

Every under-18 account is treated under the Code's standards. Standard 8 high-privacy defaults are enforced **in code** and asserted by a strict test suite covering ages 11–17 — personalised recommendations, streak gamification, behavioural nudges, non-essential analytics, marketing, social-share nudges, public leaderboards and geolocation are all off by default.

- **Minimum age 11**, with verifiable parental consent for ages 11–15 captured via a parent-link email at sign-up. UK GDPR Article 8 sets the digital age of consent at 13; for users aged 11–12 we rely on verifiable parental consent.
- **Data minimisation:** age bracket stored, not full DOB shown anywhere; opaque identifiers at the AI boundary.
- **No behavioural profiling of minors** for commercial purposes; no targeted advertising to minors.

Where the data lives

```
Qatar user → Vercel front end (global edge, ephemeral)
            → Supabase EU / Frankfurt    (account, essays, marking, consent ledger - )
            → Microsoft Azure UK South    (backend API)
            → Anthropic US                (AI marking only - no name/email/DOB/school :
            → Sentry EU / Frankfurt        (error monitoring, scrubbed)
            → Email provider US           (transactional email)
            → Stripe Ireland (UK failover) (payments - under-18 cannot enter payment
```

What we do NOT claim

- We are **not** NCSA NIA-certified (separate cybersecurity scheme; deferred).
- We do **not** yet hold an Article 16 permit reference (dossier shelf-ready; submission held).
- We are **not** ISO/IEC 27001 certified (roadmap, late 2026) or Cyber Essentials Plus certified.
- We are **not** endorsed by AQA, Pearson Edexcel, OCR, WJEC, Eduqas or Cambridge — we cover their specifications; endorsement claims would be false.
- Counter-signed sub-processor DPAs — most are pending counter-signature; the AI DPA + zero-retention confirmation are being finalised with counsel (Document 03).

Procurement pack on request

Email dpo@theenglishhub.app (subject "PDPPL diligence — [school name]") and within 5 working days we provide: the Personal Data Management System index, the RoPA, all three DPIAs, the sub-processor register with current DPA statuses, the breach runbook + NCGAA template, and the cross-border consent specification.